

1. Executive Summary

This assessment evaluates the effectiveness of access control mechanisms within a simulated enterprise environment, focusing on the **Principle of Least Privilege (AC-6)**.

The review identified critical risks related to improper privileged account usage and moderate risks involving privilege creep. While strong controls such as Role-Based Access Control (RBAC) and activity logging are in place, gaps in privilege separation and access review processes increase the organization's exposure to insider threats and credential compromise.

Key recommendations include implementing privileged access separation, enforcing Just-In-Time (JIT) access, and improving automated access reviews.

2. Scope

- Control Family: Access Control (AC)
 - Focus Area: AC-6 (Least Privilege) and enhancements AC-6(1) – AC-6(10)
 - Environment: Microsoft Azure Active Directory (Azure AD)
 - Assessment Type: Interview-based control evaluation
-

3. Methodology

- Conducted structured interviews with:
 - Chief Information Security Officer (CISO)
 - IT Manager
- Mapped responses to NIST 800-53 AC-6 controls
- Identified control gaps and weaknesses
- Assigned risk levels based on likelihood and impact

- Developed remediation recommendations aligned with industry best practices

4. Key Findings & Risk Analysis

>> Finding 1: Privileged Account Misuse (AC-6(2))

Description:

Administrative users operate with elevated privileges at all times, including during routine, non-administrative tasks.

Risk:

- Increased attack surface if credentials are compromised
- Higher likelihood of accidental or intentional misuse

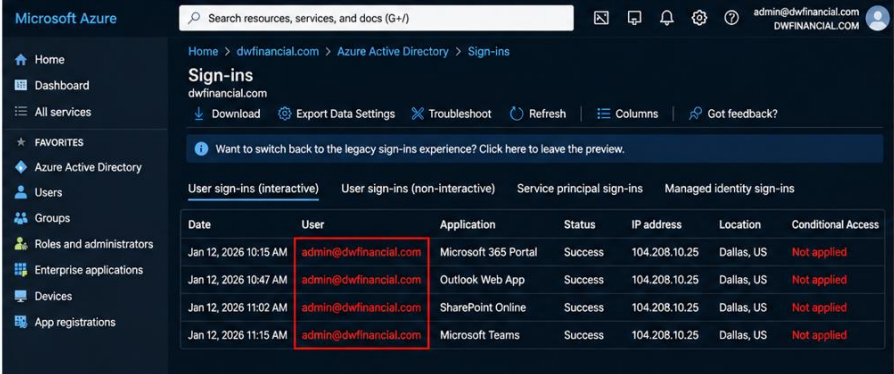
Likelihood: High

Impact: High

Risk Level: Critical

>> Evidence:

FINDING 1: PRIVILEGED ACCOUNT MISUSE (AC-6(2))



Date	User	Application	Status	IP address	Location	Conditional Access
Jan 12, 2026 10:15 AM	admin@dwfinancial.com	Microsoft 365 Portal	Success	104.208.10.25	Dallas, US	Not applied
Jan 12, 2026 10:47 AM	admin@dwfinancial.com	Outlook Web App	Success	104.208.10.25	Dallas, US	Not applied
Jan 12, 2026 11:02 AM	admin@dwfinancial.com	SharePoint Online	Success	104.208.10.25	Dallas, US	Not applied
Jan 12, 2026 11:15 AM	admin@dwfinancial.com	Microsoft Teams	Success	104.208.10.25	Dallas, US	Not applied

What this shows:

The administrative account (admin@dwfinancial.com) is being used to access routine, non-administrative applications such as Outlook, SharePoint, and Teams.

Risk:

Using privileged accounts for everyday activities increases the risk of credential compromise and misuse.

Likelihood: High
Impact: High
Risk Level: **CRITICAL**

Related Control: AC-6(2)

>> Finding 2: Privilege Creep (AC-6(7))

Description:

Users retain elevated privileges after role changes. Sample review found 2 out of 10 users with unnecessary admin access.

Risk:

- Unauthorized access accumulation over time

Finding	Likelihood	Impact	Risk Level
Privileged Account Misuse	High	High	Critical
Privilege Creep	Medium	Medium	Moderate

6. Recommended Remediations

The following remediation actions are recommended to reduce identified risks and align the environment with industry standards including NIST SP 800-53:

1. Enforce Privileged Access Separation (Critical Priority)

- Require dual-account model:
 - Standard account (daily use)
 - Privileged account (admin tasks only)
-

2. Implement Just-In-Time (JIT) Access (High Priority)

- Temporary privilege elevation
 - Remove standing administrative permissions
-

3. Automate Access Reviews (Medium Priority)

- Schedule periodic reviews
 - Auto-revoke unnecessary privileges
-

4. Enhance Monitoring & Detection (Critical Priority)

- Forward logs to SIEM
 - Alert on:
 - Privilege escalation
 - Suspicious admin activity
-

5. Apply Zero Trust Principles (Medium Priority)

- Continuous verification of access
 - Least privilege enforcement across all systems
-

7. Conclusion

The organization demonstrates a solid foundation in access control implementation; however, critical gaps in privileged account management present **significant risk**. Addressing these issues will greatly improve the organization's security posture and alignment with modern Zero Trust practices.

Prepared by:

DeAnthony Gray

Cybersecurity Analyst

DWFINANCIAL LLC